

Risk concepts and the EBIOS Risk Manager method

✓ From audit to risk: why measuring the deviation is not enough



Session objectives

By the end of this lecture:

- **Define** the vocabulary of risk: risk, severity, likelihood, risk level, feared event, risk origin, target objective
- **Situate** ISO/IEC 27005:2022 and ISO 31000:2018 in the standards landscape, and explain what sets them apart from ISO/IEC 27001:2022
- **Present** the EBIOS Risk Manager (expression of needs and identification of security objectives, the ANSSI (the French national cybersecurity agency) method) method: what it is, where it comes from, how its five

workshops chain together, and what it does not do

- **Explain** the complementarity between the compliance-based approach and the scenario-based approach, and know which one to mobilize for which type of threat
- **Prepare** Workshops 1 and 2, to be run this afternoon on the MERIDIAN group

Prerequisites

- The mapping from session 2: the MERIDIAN group's business assets and supporting assets are already identified there, and this lecture explains why that was the real first step of risk analysis.
- The session 4 audit report and its qualified deviations: they will feed directly into the security baseline.
- Risk appetite, worked on this morning: it is what the risk assessment will confront with reality.

The question the audit leaves open

Session 4 closed on an audit report: a list of deviations between what the framework requires and what the group does. It is an honest photograph, but it does not answer the question management is really asking: among these deviations, which ones can hurt, how badly, and by whose hand? An audit compares against a rule; it does not say what a motivated attacker would do with each shortcoming, nor what an outage would cost the Santé subsidiary (healthcare) on an on-call day. To move from "we are non-compliant" to "here is what we risk and here is what gets treated first", another discipline is needed: risk assessment. This lecture provides its vocabulary, its reference texts, then the method applied all afternoon.

✓ The vocabulary: six words that carry the whole edifice

First, the central word. The glossary of the EBIOS Risk Manager guide defines **risk** as follows: « Possibilité qu'un événement redouté survienne et que ses effets impactent les missions de l'objet de l'étude. » (The possibility that a feared event occurs and that its effects impact the missions of the studied object.) Every word is load-bearing. "Possibility": a risk is not a fact, it is a plausible future; it is therefore handled with estimates, never with certainties. "Feared event": risk starts from what the organization fears for what matters, not from a list of attack techniques. "Missions": the final measure of risk is business, not IT. An encrypted database that goes down with no consequence for any mission carries almost no risk; a seemingly harmless file share that conditions a hospital's admissions carries a great deal.

A risk is then estimated along two independent dimensions. Its **severity** answers "if it happens, how badly does it hurt": « Estimation du niveau et de l'intensité des effets d'un risque » (estimation of the level and intensity of a risk's effects), says the glossary. Its **likelihood** answers "how much can this happen": « Estimation de la faisabilité ou de la probabilité qu'un risque se réalise, selon l'échelle adoptée. » (Estimation of the feasibility or probability

that a risk materializes, according to the adopted scale.) And their combination gives the **risk level** itself: « Mesure de l'importance du risque, exprimée par la combinaison de la gravité et de la vraisemblance. » (Measure of the risk's importance, expressed by the combination of severity and likelihood.) Worth remembering: these two dimensions do not offset each other morally: a catastrophic event that is very hard to carry out and a benign but daily incident can end up at the same risk level, and yet call for very different treatments. The grid combines; judgment arbitrates.



Three actors then populate this vocabulary. The **feared event** is defined by the glossary as attached to a business asset: it « porte atteinte à un critère ou besoin de sécurité de la valeur métier » (harms a security criterion or security need of the business asset), and « chaque événement redouté est estimé selon le niveau de gravité des conséquences, à partir d'une métrique » (each feared event is estimated according to the severity level of its consequences, based on a metric). The building blocks of session 2 are recognizable here: the business assets and supporting assets, defined during the mapping, are reused as they are, and the already-rated DICT (availability, integrity, confidentiality, traceability, the French acronym kept by the module) security needs serve as a guide for phrasing what is feared: harm to the availability, integrity, confidentiality or traceability of each business asset.

The **risk origin**, for its part, designates « élément, personne, groupe de personnes ou organisation susceptible d'engendrer un risque » (an element, person, group of people or organization likely to give rise to a risk), caractérisable « par sa motivation, ses ressources, ses compétences, ses modes opératoires » (by its motivation,

resources, skills and operating modes). And the **target objective** is the « finalité visée par une source de risque, selon ses motivations » (the end pursued by a risk origin, according to its motivations). The distinction between the last two is finer than it looks: the target objective is what the attacker wants to obtain (stealing know-how, extorting a ransom), the motivation is what drives them to it (greed, ideology, revenge). The guide explicitly warns against confusing them, and the midday quiz will not forgive it either.

Term	The question it answers	MERIDIAN example
Business asset (session 2)	What matters for the mission?	Patient record management at the Santé subsidiary
Supporting asset (session 2)	What does it rest on?	The health data DBMS (database management system)
Feared event	What is feared for this business asset?	The disclosure of patient records
Risk origin	Who or what could cause it?	A cybercriminal group
Target objective	To obtain what?	Extorting a ransom from the group
Risk level	How much does it matter, all things considered?	Combination of severity and likelihood

This table reads top to bottom, and that order is not decorative: it is the order of the method to apply. Start from what matters, phrase what is feared, look for who could cause it, and finish by measuring. A line of reasoning that begins with “what are our servers' vulnerabilities” takes the problem backwards: it will produce a technical inventory without ever telling management what threatens the missions.

✓ The texts: what requires, what guides, what equips

Three references share the field, and confusing them is the most widespread mistake in the domain. The bibliography of the EBIOS Risk Manager guide cites them in these exact terms: « ISO 31000:2018, Management du risque, Principes et lignes directrices », « ISO 27001:2022, Systèmes de management de la sécurité de l'information, Exigences », and « ISO 27005:2022, Préconisation pour la gestion des risques liés à la sécurité de l'information ».

The titles say almost everything. **ISO 31000:2018** deals with risk management in general: financial, industrial, legal, digital, any organizational risk. It is the shared conceptual foundation, the one the module's assessment vocabulary descends from. **ISO/IEC 27001:2022** is titled « Exigences » (Requirements): it is the standard of session 3, the one organizations get certified against, and it notably requires that the organization assess and treat its information security risks. But requiring is not explaining how. **ISO/IEC 27005:2022**, fourth edition published in

October 2022, is precisely that user manual: guidance, not a requirements standard; no one gets certified against ISO 27005, one draws on it to build a risk management process. Session 7 will walk through that standardized process end to end, from context establishment to treatment and monitoring; today, it is enough to know where the standard sits and what it is not.

There remains the question every student asks at this point: if the international standards cover the subject, why a French method? Here is its identity sheet.

Concept sheet: EBIOS Risk Manager

The problem it answers: an organization that wants to assess its digital risks faces normative texts that describe WHAT to do without detailing HOW to go about it, with whom around the table, in what order and with which deliverables. The method fills exactly that void. What it is, according to the guide's foreword: « EBIOS Risk Manager (EBIOS RM) est la méthode d'appréciation et de traitement du risque numérique publiée par l'Agence nationale de la sécurité et des systèmes d'information (ANSSI) avec le soutien du Club EBIOS. » (EBIOS Risk Manager (EBIOS RM) is the digital risk assessment and treatment method published by the French national agency for information systems security (ANSSI) with the support of Club EBIOS.) Its current version is v1.5, published in September 2024.

Its mechanics: five workshops that run from the most strategic (the missions, what is feared) to the most technical (attack operating modes), then climb back up toward decision (treatment). Its articulation with the standards is explicit: the guide declares itself compatible with the frameworks in force, « en particulier les normes de la série ISO/IEC 27000 et notamment 27005:2022 avec laquelle la méthode EBIOS RM est conforme » (in particular the standards of the ISO/IEC 27000 series, notably 27005:2022, with which the EBIOS RM method is compliant). Its limit, finally: it is an assessment and treatment method, not a security guarantee nor a catalog of controls; it organizes collective judgment, it does not replace it, and the quality of its results is worth what the assembled participants and the information given to them are worth.

In other words: ISO 27001 requires, ISO 27005 guides, EBIOS RM equips. The three complement rather than compete with one another, and a group CISO generally mobilizes them together: the requirements standard for the management system, the guidance for the process, the method for the concrete workshops.

✓ Two approaches that share the work

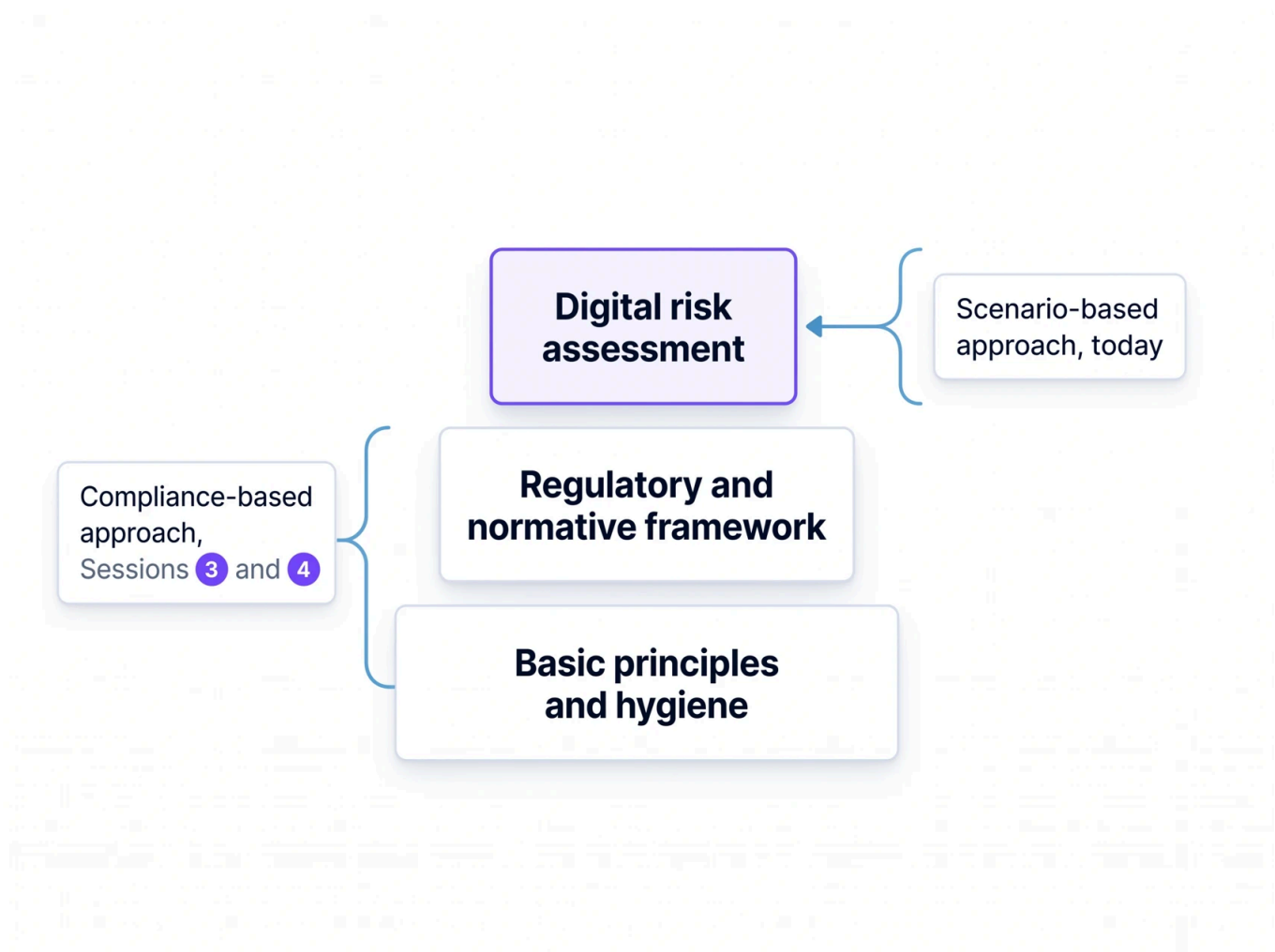
The method rests on a simple and powerful idea, symbolized by its digital risk management pyramid. The guide phrases it this way: the full set of risks is grasped through the combination « d'une approche par conformité pour déterminer le socle de sécurité pour les risques les plus communs, y compris ceux liés à des événements accidentels et environnementaux ; et d'une approche par scénarios pour identifier les risques avancés, d'origine intentionnelle, et notamment les attaques particulièrement ciblées ou sophistiquées » (of a compliance-based approach to determine the security baseline for the most common risks, including those tied to accidental and

environmental events; and a scenario-based approach to identify advanced risks, of intentional origin, notably particularly targeted or sophisticated attacks).

Two real incidents illustrate why this division of labor exists. In 2017, the WannaCry campaign produced, according to the first reports collected by the American CISA (the US cybersecurity agency), tens of thousands of infections in more than 150 countries: a self-propagating, untargeted ransomware that struck any unpatched machine. Against that type of threat, building custom attack scenarios brings nothing; what protects is the baseline, hygiene, applied patches, in other words compliance with known frameworks. Conversely, the SolarWinds compromise, discovered in December 2020, distributed a booby-trapped update of the Orion product to about 18,000 public and private customers: a prepared, patient attack going through the software supply chain. No list of good practices is enough to reason about that case; one must take the attacker's place and imagine their paths, and that is exactly what the scenario-based approach does.

	Compliance-based approach	Scenario-based approach
Risks targeted	The most common, including accidental and environmental	Advanced, intentional, targeted or sophisticated
Question asked	Are we applying the recognized rules?	What would a motivated risk origin do?
Material	Frameworks, guides, regulations, PSSI (the group's framework information security policy, French acronym)	Risk origins, attack paths, operating modes
Where in the method	Workshop 1: the security baseline	Workshops 2 to 4: risk assessment
Typical threat	Opportunistic ransomware, WannaCry-style	Prepared compromise, SolarWinds-style

The pyramid arranges these two approaches into three tiers: basic principles and hygiene at the bottom, the regulatory and normative framework in the middle, digital risk assessment at the top. The first two tiers belong to compliance, the last one to scenarios. The module's trajectory follows this pyramid exactly: sessions 3 and 4 worked through the two compliance tiers (choosing the framework, auditing the deviation), and the third is climbed today. That is also why the guide's glossary specifies that risk assessment, « ensemble du processus d'identification, d'analyse et d'estimation des risques » (the whole process of risk identification, analysis and estimation), corresponds in the EBIOS RM approach to Workshops 2, 3 and 4: Workshop 1 is the prerequisite of the assessment, the one that sets the frame and the baseline, and Workshop 5 is its decision-making culmination.



✓ Five workshops, two cycles: the mechanics

Here is the entire method at a glance. The headings are those of the guide, to be used as they are in the deliverables.

Workshop	Exact title	The question it answers	What comes out of it
1	Scope and security baseline	What does the study cover, and where does our compliance stand?	Framing, missions, business assets and supporting assets, feared events and severity, baseline and deviations
2	Risk origins	Who could attack us, and to obtain what?	Selected and mapped risk origin / target objective pairs
3	Strategic scenarios	Through which paths, across our ecosystem?	Strategic scenarios and attack paths, estimated in severity
4	Operational scenarios	Concretely, on which supporting assets, through which actions?	Operational scenarios estimated in likelihood
5	Risk treatment	What is decided, and what remains afterwards?	Treatment strategy, treatment plan, residual risks, monitoring framework

Two logics run through this table and deserve to be stated explicitly. The first is the mechanics of measurement: severity is born upstream, carried by the feared events of Workshop 1 and passed on to the strategic scenarios of Workshop 3; likelihood is born downstream, estimated on the operational scenarios of Workshop 4; and the risk level, specific to each risk scenario, combines the two in Workshop 5. The guide sums it up in a note: « en général, chaque chemin d'attaque d'un scénario stratégique donne lieu à un scénario opérationnel. Un scénario de risque correspond à l'association d'un chemin d'attaque et de son scénario opérationnel. » (In general, each attack path of a strategic scenario gives rise to an operational scenario. A risk scenario corresponds to the association of an attack path and its operational scenario.) Mastering Workshops 3 and 4 is not necessary today: session 6 will run them on the group's ecosystem, its providers and its supply chain, where they take on their full meaning.

The second logic is time. The method is not an exercise done once: « La démarche prévoit deux cycles, dont les durées sont définies lors du premier atelier : un cycle stratégique revisitant l'ensemble de l'étude et en particulier les scénarios stratégiques ; un cycle opérationnel revenant sur les scénarios opérationnels à la lumière des incidents de sécurité survenus, de l'apparition de nouvelles vulnérabilités et de l'évolution des modes opératoires. » (The approach provides for two cycles, whose durations are set during the first workshop: a strategic cycle revisiting the whole study and in particular the strategic scenarios; an operational cycle returning to the operational scenarios in light of security incidents that have occurred, newly discovered vulnerabilities and changes in operating modes.) To fix ideas, the guide states that for the security authorization (homologation) of an information system, « les durées sont de trois ans pour le cycle stratégique et d'un an pour le cycle opérationnel » (the durations are three years for the strategic cycle and one year for the operational cycle). Risk analysis is thus a living organism: the top of the edifice moves slowly, the bottom is re-evaluated at the pace of the threat.

The EBIOS Risk Manager approach, as the tool presents it



Workshops and activities as named in CISO Assistant v3.21, EBIOS RM module; workshop titles from the ANSSI guide

One last character trait, which avoids a frequent misreading: the method presents itself as an adaptable toolbox, not as a mandatory full rite. The guide offers a usage grid that adjusts which workshops to run according to the objective: identifying only one's security baseline can be done with Workshop 1 alone; a complete study in view of a security authorization mobilizes them all. Faced with an organization that "does EBIOS" by mechanically filling in five templates without asking what its study is for, the conclusion is unavoidable: the spirit of the method got lost along the way.

Workshops 1 and 2 at MERIDIAN: the afternoon's work

Back to the concrete, because the afternoon is entirely devoted to it. Workshop 1 opens the study, and its first step is an act of governance more than of technique: defining the study's objective, identifying the participants and their roles, setting the time frame of the two cycles. The guide insists on a point taken up in the deliverable's criteria: « il est indispensable d'identifier quelle est la personne responsable d'accepter les risques résiduels au terme de l'étude » (it is essential to identify the person responsible for accepting the residual risks at the end of the study). At MERIDIAN, the governance from session 1 gives the answer: Executive Management, which sets the appetite, is the only body with the legitimacy to accept what will remain below it. This morning's CISO briefing prepared exactly what this step needs.

Then comes the business and technical scope: missions, business assets, supporting assets. And this is where session 2 delivers on its promise. These objects are not invented in a workshop: they are TAKEN OVER from the mapping, in the same terms. The EBIOS guide says it itself: to list the supporting assets, « appuyez-vous sur la cartographie du système d'information de l'organisme » (rely on the organization's information system map), and its note refers explicitly to the ANSSI guide « Cartographie du système d'information, guide d'élaboration en 5 étapes », the very one applied in session 2.

An organization without a map has to improvise this step in a working session, with the holes and omissions that implies; the Group CISO, for their part, arrives with the material ready. The guide moreover recommends staying frugal: « 5 à 10 valeurs métier constituent généralement une base suffisante pour orienter la suite de l'étude » (5 to 10 business assets generally constitute a sufficient basis to steer the rest of the study), and one to three supporting assets per business asset are enough at this stage. The Top 5 critical assets from session 2 fall exactly within that outline.

Next come the feared events and their severity, phrased business asset by business asset by walking through the DICT needs, then the security baseline: « liste des référentiels applicables, état d'application, identification et justification des écarts » (list of applicable frameworks, state of application, identification and justification of deviations), according to the workshop's output data. Here again, the Group CISO does not arrive empty-handed: the framework chosen in session 3 and the audit report from session 4 ARE the requested state of application. Workshop 1 does not redo the audit, it consumes it, and draws from it a decision the guide phrases bluntly: if the deviations are too significant, reinforce the baseline before continuing; otherwise, « poursuivre en considérant la non-conformité, les scénarios de risques viendront exploiter les éventuelles fragilités du socle de sécurité » (continue while factoring in the non-compliance; the risk scenarios will come to exploit any weaknesses in the security baseline).

Workshop 2, finally, switches sides: after looking at what matters to the group, the workshop looks at who might take an interest in it. Its founding question, according to the guide: « qui ou quoi pourrait porter atteinte aux missions et valeurs métier identifiées dans l'atelier 1, et dans quels buts ? » (who or what could harm the missions and business assets identified in Workshop 1, and to what ends?) The risk origins and their target objectives are inventoried, the relevance of each pair is evaluated against three criteria, motivation, resources and activity, and the priority pairs are then selected: « 3 à 6 couples SR/OV constituent généralement une base suffisante pour élaborer des scénarios stratégiques » (3 to 6 risk origin / target objective pairs generally constitute a sufficient basis to build strategic scenarios).

And the loop closes elegantly: the guide recommends confronting the defender's point of view, the feared events, with the attacker's, the RO/TO (risk origin / target objective) pairs, to check that no serious feared event is left without a plausible origin, and vice versa. At MERIDIAN, the candidates can already be guessed: health data attracts extortion, the logistics chain fears interruption, a citizen services platform attracts those looking for a sounding board. The afternoon will decide with the rigor of the grid, not with intuitions.

✓ What the method does not promise

This lecture closes on the limits, because an expert is recognized by knowing what not to ask of their tools. Risk assessment predicts nothing: it ranks plausibilities to inform decisions, and a risk rated low can materialize tomorrow. It does not replace appetite: the grid says where each risk sits, the appetite says where the line of the acceptable runs, and that line is a management decision, not the result of a calculation. Finally, it is worth what its material is worth: a false map produces a false study with the same confidence. The CHU (university hospital) de Rouen (Rouen university hospital), hit by ransomware in 2019, reminded the French hospital sector that digital risk

is paid in stretchers and postponed care, not only in euros: when facilitating the workshops this afternoon, that is the reality the severity scales must capture, and it is for that reality that rigor of vocabulary is not an academic luxury.

At midday, the quiz checks the vocabulary and the mechanics of Workshops 1 and 2. The afternoon runs these two workshops on MERIDIAN, enters their results into CISO Assistant, then sets the group's scales and assembles the first risk assessment deliverable. The mapping has stopped being an exercise: it becomes a weapon.